

Universidad San Carlos de Guatemala
Facultad de ingeniería.
Ingeniería en ciencias y sistemas



Práctica 2:

Autenticación y Autorización

PONDERACIÓN: 1.5 pts

 **Tiempo estimado: 10 hrs/min**



Índice

1. MARCO FORMATIVO	3
1.1. Valor	3
1.2. Competencia(s)	3
1.3. Habilidad(es) blandas a formar	3
2. Resultado del Aprendizaje	3
2.1. Objetivo SMART	3
3. Enunciado de la Práctica	4
3.1 Descripción del problema a resolver	4
3.2 Alcance de la práctica	4
4. Entregables	5
5. Material de apoyo	5
6. Recursos y herramientas a utilizar	5
7. Cronograma	6
8. Rúbrica de Calificación	6
8.1 Requisitos para optar a la calificación	6
8.2 Resumen de Puntuaciones	7
Detalle de la Calificación	8
Comentarios Generales	9

1. MARCO FORMATIVO

1.1. Valor

Nombre del valor	¿Cómo se aplica en tu laboratorio?
Responsabilidad	El estudiante entrega un proyecto individual funcional, respetando fechas límite y normas de integridad académica.
Seguridad y ética profesional	El manejo correcto de datos sensibles (encriptación, tokens, cookies seguras) refleja el compromiso ético del ingeniero con la protección de la información de los usuarios.

1.2. Competencia(s)

Con la elaboración de esta práctica usted adquirirá la siguiente competencia:

Implementar un módulo completo de autenticación y autorización en una aplicación full-stack, aplicando mecanismos de seguridad modernos como JWT, cookies HTTP-only y encriptación AES, bajo buenas prácticas de desarrollo de software.

1.3. Habilidad(es) blandas a formar

La práctica le permitirá desarrollar las siguientes habilidades:

- **Individual:** Toma de decisiones técnicas justificadas, al elegir libremente el stack tecnológico (lenguaje, framework, base de datos) y argumentar sus ventajas y desventajas.
- **Individual:** Comunicación técnica escrita, mediante la redacción de documentación clara en Markdown que incluye diagramas y explicaciones de tecnologías.
- **Individual:** Responsabilidad bajo presión, al tener que defender y modificar su propio código durante la calificación oral.

2. Resultado del Aprendizaje

2.1. Objetivo SMART

Específico (¿Qué?)	Medible (¿Cuánto?)	Alcanzable (¿Cómo?)	Realista (¿Para qué?)	A Tiempo (¿Cuándo?)
Desarrollar un módulo de registro, login y autorización por roles (Admin/Cliente) en una	El estudiante implementará los 4 flujos requeridos (registro, login, renovación de token,	Mediante el stack tecnológico de libre elección (JS/TS o Python recomendado), una base de	Para desarrollar competencias en seguridad web aplicada, esencial en cualquier sistema que	Antes del x de Julio de 2026 a las 23:59 hrs, entregando el repositorio vía UEDI.

aplicación full-stack, con autenticación mediante JWT almacenado en cookies HTTP-only y datos encriptados con AES.	autorización por roles), documentará las tecnologías utilizadas e incluirá un diagrama de secuencia funcional.	datos relacional, y variables de entorno para la configuración del JWT.	maneje información sensible de usuarios.	
--	--	---	--	--

3. Enunciado de la Práctica.

3.1 Descripción del problema a resolver

El estudiante se encuentra trabajando en un sprint de desarrollo y debe implementar un **módulo de registro y login** para una aplicación. El líder del proyecto le otorga libertad para elegir las herramientas de frontend, backend y base de datos relacional que mejor domine, pero impone restricciones específicas de seguridad para garantizar que el código sea reutilizable a futuro.

El sistema debe contemplar dos tipos de roles: **Admin** y **Cliente**, con acceso diferenciado a rutas protegidas:

Rol	Ruta 1 (Solo Admin)	Ruta 2 (Admin y Cliente)
Admin	Acceso permitido	Acceso permitido
Cliente	Acceso denegado	Acceso permitido

3.2 Alcance de la práctica

El módulo deberá cumplir obligatoriamente con las siguientes restricciones:

1. La comunicación entre frontend y backend se realizará usando una API REST.
2. La autenticación debe implementarse usando JWT.
3. El token no puede estar almacenado en ningún lugar visible por el usuario (se recomienda el uso de cookies, especialmente de tipo HTTP-only).
4. El JWT debe tener un tiempo de vida configurable mediante una variable de entorno.
5. Se debe implementar la renovación automática del JWT cuando haya expirado y haya transcurrido menos de un tiempo X desde su vencimiento (también configurable por variable de entorno).
6. Toda información sensible (nombres, correos, contraseñas, etc.) debe almacenarse encriptada (se recomienda el algoritmo AES).
7. Debe existir una página de confirmación visible tras un login exitoso.

8. Se deben implementar dos endpoints protegidos por roles, validando que Admin acceda a ambos y Cliente solo a uno.
9. La autorización debe implementarse como un servicio independiente (microservicio de autorización), desacoplado del servicio de autenticación, que reciba el token/permiso a validar y responda si el acceso está permitido o denegado. El backend debe consultar este servicio mediante un mecanismo de reintentos con espera (polling/retry loop) ante fallas temporales o timeouts, con un número máximo de reintentos y un backoff configurable, antes de denegar el acceso por error de comunicación.

3.3 Requerimientos técnicos

- **Frontend y backend:** Elección libre (se recomienda JavaScript/TypeScript o Python).
- **Base de datos:** Relacional, de elección libre (PostgreSQL, MySQL, etc.).
- **Autenticación:** JWT con almacenamiento en cookies HTTP-only.
- **Encriptación:** Algoritmo AES para datos sensibles en base de datos.
- **Configuración:** Variables de entorno para el tiempo de vida del JWT y el tiempo de gracia para renovación.
- **Repositorio:** Privado en la nube (GitHub, GitLab, Bitbucket), con carpeta **P2** y nombre **Practicas-SA-<<SECCIÓN>>-<<CARNE>>**.
- **Servicio de autorización:** Microservicio independiente que valida permisos por rol; el backend principal debe consultarlo mediante un ciclo de reintentos (retry loop) con backoff y número máximo de intentos configurables.
- Agregar al auxiliar con rol Developer: **Usuario: KevinPozuelos**.

4. Entregables

Tipo	Descripción
Repositorio en la nube	Repositorio privado con el código fuente de la API REST, organizado dentro de la carpeta P1 .
README en Markdown	Documento que incluye: explicación con palabras propias de los 5 principios SOLID y evidencia de su aplicación en el código (archivo/clase, justificación y fragmentos de código reales).
Enlace en UEDI	Subir el enlace del repositorio a la plataforma UEDI antes de la fecha límite.

5. Material de apoyo

- [Documentación oficial de JWT](#)
- [Guía de cookies HTTP-only \(MDN\)](#)
- [Algoritmo AES — Explicación](#)
- [Cómo crear diagramas de secuencia con Mermaid](#)
- [Guía de Markdown](#)
- [Buenas prácticas REST](#)

6. Recursos y herramientas a utilizar

- **Software/Hardware:** Computadora con entorno de desarrollo local instalado según el stack elegido.
- **Base de datos:** Relacional de elección libre (PostgreSQL, MySQL, SQLite, etc.).
- **Plataformas:** GitHub / GitLab / Bitbucket (repositorio), UEDI (entrega).
- **Lecturas recomendadas:** Documentación oficial de JWT, guías de seguridad web (OWASP), documentación del framework elegido.

7. Cronograma

Tipo	Fecha Inicio	Fecha Fin
Asignación de Práctica	30/07/2026	30/07/2026
Elaboración	30/07/2026	06/08/2026
Calificación	08/08/2026	08/08/2026

8. Rúbrica de Calificación

8.1 Requisitos para optar a la calificación

Antes de la evaluación de la práctica, los estudiantes deben cumplir con los requisitos que se indiquen en esta sección.

Tema	Descripción	Cumple (Sí/No)
Repositorio	Repositorio privado creado con el formato de nombre correcto y carpeta P2 incluida.	

Acceso al auxiliar	Usuario KevinPozuelos agregado con rol Developer.	
Entrega en UEDI	Enlace del repositorio subido antes del 17 de febrero de 2026 a las 23:59 hrs.	
Trabajo individual	La práctica fue realizada de forma individual, sin copias parciales ni totales.	
Último commit	El último commit fue subido antes de la hora y fecha de entrega.	

8.2 Resumen de Puntuaciones

Área	Puntos Totales	Puntos Obtenidos
1. Habilidades		
Módulo de registro y login funcional	25	
Implementación de JWT con cookies HTTP-only y renovación automática	20	
Autorización por roles (Admin / Cliente)	15	
Sub-Total Habilidades	60	
2. Conocimiento		
Encriptación AES de datos sensibles	15	

Documentación README (tecnologías, JWT, AES, cookies, diagrama de secuencia)	25	
Sub-Total Conocimiento	40	
TOTAL	100	

Detalle de la Calificación

	Criterio/Nivel			Nivel de evaluación		
No.	Criterio de evaluación	Punteo maximo		Satisfactorio 100% - 61%	Necesita mejorar 60% - 0%	Punteo Obtenido
1	Habilidades					
1.1	Módulo de registro y login funcional con página de confirmación	25	Descripción	El registro y login funcionan correctamente, los datos se persisten en base de datos relacional y existe una página visible tras el login exitoso.	Faltan endpoints, no funcionan correctamente o no siguen las convenciones REST.	
			Rango del punteo			
1.2	JWT almacenado en cookie HTTP-only con tiempo de vida y renovación automática configurables por variables de entorno	20		El JWT se almacena en cookie HTTP-only, el tiempo de vida y el tiempo de gracia para renovación son configurables por variables de entorno y la renovación automática funciona correctamente.	El código no aplica los principios SOLID de forma evidente o su aplicación	

1.3	Autorización por roles: Admin accede a ambas rutas, Cliente solo a Ruta 2	15		Ambos endpoints están protegidos correctamente; Admin accede a los dos y Cliente es denegado en Ruta 1 con el código HTTP apropiado. La autorización se resuelve a través de un servicio de autorización independiente, consultado mediante un ciclo de reintentos (retry loop) que maneja correctamente fallas temporales.	Los roles no están implementados, no se validan correctamente, el acceso no está restringido según lo especificado, o la autorización no se implementa como un servicio independiente con reintentos.	
	Sub-Total de Puntos					
2	Conocimientos					
2.1	Encriptación AES de datos sensibles en base de datos	15	Descripción	Nombres, correos y contraseñas están almacenados de forma encriptada usando AES y se desencriptan correctamente en el flujo de autenticación	Los datos se almacenan en texto plano, la encriptación es incorrecta o no aplica AES.	
			Rango del punteo			
2.2	Documentación README: instrucciones de ejecución, explicación de tecnologías (ventajas/desventajas)	25		El README cubre todos los puntos requeridos con explicaciones propias, el diagrama de secuencia es correcto y las instrucciones permiten ejecutar el proyecto sin ambigüedades. .	Faltan secciones requeridas, las explicaciones son copiadas textualmente, el diagrama está ausente o es incorrecto, o las instrucciones son incompletas.	

	), JWT, AES, cookies HTTP-only y diagrama de secuencia					
	Sub-Total de Puntos	40				
	Total	100				